API Security Guidelines (2026)

All public endpoints must be served over HTTPS with TLS 1.2 or newer. Access tokens expire after 15 minutes and refresh tokens after 7 days.

Service and user passwords must be rotated every 90 days. Secrets such as database passwords and API keys must be stored in the secrets vault, never in source code or environment files committed to git.

Every public API must enforce a rate limit of 100 requests per minute per client and return HTTP 429 when the limit is exceeded.

Input validation and logging

All request bodies must be validated against a schema before use. Application logs must never contain passwords, tokens or full card numbers. Security-relevant events such as failed logins and permission changes must be written to the audit log.

Dependencies must be scanned for known vulnerabilities on every pull request and critical findings must be fixed within 7 days.